

NostrAgent: A Decentralized Identity and Delegation Architecture for Sovereign Agentic Systems

Oliver Aleksander Larsen¹ and Mahyar Tourchi Moghaddam¹

University of Southern Denmark, Odense, Denmark
 {olar,mtmo}@mmmi.sdu.dk

Abstract. Autonomous AI agents increasingly act across organizational boundaries on behalf of human operators: they invoke third-party services, delegate subtasks to other agents, and pay for metered resources. Deploying such agents safely requires five capabilities that today live in separate systems: persistent identity, scoped delegation, peer trust, discovery, and payment. Existing approaches root these capabilities in centralized authorities or cover only subsets, so authority, trust, and payment fracture exactly where autonomy needs continuity: when a key rotates or a delegation must be revoked. We present NostrAgent, a decentralized architecture that unifies all five capabilities over Nostr relays using three custom event kinds: Kind 38100 identity declarations authenticated by BIP340 Schnorr signatures with pre-rotation commitments, Kind 38101 scoped delegation chains whose every hop verifiably narrows the granted capabilities, and Kind 38102 peer attestations forming a Sybil-deterrent trust graph, with Lightning HTTP 402 (L402) binding payment to agent identity. Identity remains operator-sovereign: the human operator controls it without any registration authority, relays are substitutable transport rather than a trust root, and every authorization decision is replayable offline from signed events, supporting interpretability and audit. We evaluate a Python prototype with a mixed-method design: Architecture Tradeoff Analysis Method (ATAM) quality analysis with a two-round mini-Delphi expert panel, STRIDE threat modeling (Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of privilege) across three trust boundaries, eleven benchmarks with non-parametric statistics, and 19 failure modes. Measured results show sub-millisecond offline verification, linear delegation-chain scaling, and end-to-end Lightning-settled L402 at 157 ms median on regtest. 17 of 19 failure modes pass empirical tests, one is bounded analytically, and one is disclosed as an architectural limitation. NostrAgent demonstrates an auditable prototype substrate for trustworthy agentic systems without centralized trust roots.

Keywords: AI agents · trustworthy agents · decentralized identity · scoped delegation · multi-agent trust · Nostr · BIP340 · L402

This manuscript has been accepted as a Full Paper for presentation at the AIPAA special session of the 2nd International Conference on Agentic and Generative Techniques in Intelligent Computational Systems (AGENTICS) 2026, held in Angers, France, 28 – 30 October 2026, and for publication in Springer Communications in Computer and Information Science (CCIS) proceedings. This is the author’s accepted manuscript version. The final authenticated publication will be available via Springer.

1 Introduction

Consider a logistics operator *O* that deploys an autonomous forecasting agent *A*. *A* discovers third-party weather-data services, spawns a retrieval sub-agent *B* and hands it a narrow slice of its own authority (read-only weather queries, expiring in 24 hours), and pays a data service *S* per query over Lightning. Every step crosses an organizational boundary, carries delegated authority, and moves money. When *O* suspects that *A*’s key has been compromised, *O* must rotate it without losing *B*’s delegation, *A*’s accumulated peer reputation, or access to services *A* has already paid. The scenario runs through the paper: Section 4 walks each mechanism through it, and Section 5 measures it.

Interactions of this kind demand five capabilities. *Identity*: *A* and *B* must be persistently and verifiably identifiable to parties that have never met their operator. *Delegation*: *B* must prove it acts within a scope *A* granted, and *S* must check that proof without calling anyone. *Trust*: a newcomer choosing between competing weather agents needs evidence beyond self-description. *Discovery*: *A* must find *S* without a central catalog that can exclude either of them. *Payment*: cross-organizational agent services are metered in practice, as emerging agent-commerce rails assume [33,9], and here payment is also a security mechanism: the per-identity cost floor makes peer trust expensive to fabricate (Section 5.3). Identity is *operator-sovereign* when the human operator controls it, its rotation, and its delegations without any external registration authority. Decentralized architecture is the means. Operator sovereignty is the property it guarantees.

Today these five capabilities live in separate systems: an OAuth authorization server, a DID registry with its credential specifications, a reputation service, a service catalog, and a billing rail. The seams between them are where autonomy breaks: each layer keeps its own key material, so one rotation traverses several unrelated lifecycles or silently orphans state; revocation does not cascade across layers; each layer brings a trust root to reconcile; and authorization needs online round-trips exactly where agents need local, offline decisions. Unifying the five capabilities on one substrate, one key type, one event log, and one revocation primitive removes these seams: authorization becomes a local check over signed events, and one event revokes an entire delegation subtree (Section 5).

Recent analyses of agentic frameworks report a maturing but fragmented landscape with limited memory models, basic reasoning, and uneven ecosystem support, and find security largely underdeveloped [43]. Architecture evaluation methods for foundation-model agents likewise treat security as a first-class quality attribute [25]. We name the identity-layer deficits precisely:

- **G1 (Key continuity)**: rotate an agent key without losing identity, delegations, or accumulated trust.
- **G2 (Attenuated delegation)**: pass authority onward such that every hop verifiably narrows scope, with cascading revocation.
- **G3 (Peer trust attestation)**: establish capability-specific trust without a central reputation authority, at a cost that deters Sybil fabrication.
- **G4 (Registry-free discovery)**: find agents and their endpoints without a registration authority.

- **G5 (Identity-bound payment):** pay for service access with credentials that are useless to a thief.

Existing systems cover subsets: OAuth 2.1 [19], AAP [10], and SAGA [42] root identity in a central provider (G4, and G1 becomes the provider’s); W3C DIDs [41] compose G2 and G3 from separate specifications; KERI/ACDC [38,39] is strongest on G1 and G2 but offers no relay discovery or payment binding; AIP’s self-certifying mode [32] lacks rotation, attestation, and payment; UCAN [46] attenuates capabilities without G1, G3, or G5; emerging IETF WIMSE (Workload Identity in Multi System Environments) [26], NIST [6], and OWASP [28] efforts address slices in parallel. Section 3 substantiates this per system (Table 2). No surveyed system provides G1 through G5 on one substrate, and Section 5.3 evaluates against exactly these gaps.

We investigate three research questions, answered in Section 5. **RQ1** asks how NostrAgent’s design choices trade among sovereignty, operability, and trust. **RQ2** asks whether unifying identity, trust, and payment yields architectural advantages over composing separate systems. **RQ3** asks what failure modes arise in an operator-sovereign, relay-based architecture.

This paper makes the following contributions:

- C1.** A unified operator-sovereign identity architecture with three custom Nostr event kinds (Kind 38100 identity, Kind 38101 delegation, Kind 38102 peer attestation), relay-based discovery via NIP-01 filters, pre-rotation key commitment, and L402 Lightning payment integration (Section 4; evaluated against G1-G5 in Section 5.3).
- C2.** Verifier-checked attenuated delegation chains in which each hop verifiably narrows scope, time bounds, and depth, with cascade revocation through parameterized replaceable events (Section 4.3).
- C3.** A mixed-method evaluation combining reduced-scope ATAM [21,36] with a two-round mini-Delphi [11] expert panel, benchmarks across 37 metrics, STRIDE threat modeling [37], and 19 failure modes (Section 5).
- C4.** An open-source Python prototype covering the full architecture on regtest Lightning, released as a reproducibility artifact (Section 4.7; Data Availability).

2 Background

2.1 Agents, Operators, and the Protocol Ecosystem

An *agent* is an autonomous software process, today typically driven by a large language model, that plans and acts on behalf of a human or organizational *operator*. *Delegation* passes a subset of an agent’s authority to another agent. *Attenuation* is the requirement that each hand-off narrows that authority and never widens it. The running example instantiates these roles: operator O, delegating agent A, delegatee B, service S.

Two protocols dominate how agents interact. The Model Context Protocol (MCP) [3] standardizes how an agent invokes tools and resources; Agent2Agent

Table 1: Recurring terms used before or beyond their defining subsection.

Term	Meaning
d-tag	Operator-chosen stable identifier keying a replaceable event
Preimage	Secret whose SHA256 hash locks a payment; proof of settlement
Satoshi (sat)	Smallest Bitcoin unit; Lightning payments are denominated in sats
Regtest	Local, deterministic Bitcoin/Lightning test network
Pre-rotation	Commitment to the hash of the next key before that key is ever used
Noisy-OR	Combination rule treating each trust path as independent evidence
ATAM	Architecture Tradeoff Analysis Method; scenario-based quality evaluation
STRIDE	Threat taxonomy over six categories (the rows of Table 8)
B, FM, TP, SP	Benchmark, failure mode, trade-off point, sensitivity point (Section 5)

(A2A) [1] standardizes messaging between agents. Neither specifies who an agent *is*, what authority it carries, or how it pays. NostrAgent is compositional with both rather than competing: Kind 38100 identity declarations carry MCP and A2A endpoint URLs (Section 4.2), so a NostrAgent identity wraps the protocols agents already speak. Table 1 collects recurring terms.

2.2 BIP340 Schnorr Signatures

BIP340 [45] defines Schnorr signatures over the secp256k1 elliptic curve. Public keys use a compact 32-byte x-only representation, and signatures are 64 bytes ($R||s$). Verification is deterministic. Because Bitcoin, Lightning, and Nostr all build on secp256k1, NostrAgent can bind a BIP340 identity key to a Lightning-settled macaroon without introducing a new trust root.

2.3 Nostr Relay Model

Nostr is a relay-based protocol where clients exchange JSON events over WebSocket connections to relay servers [17]. Each event carries a BIP340 signature from its author, so relays can store and forward events but cannot forge them. Event kinds 30 000 through 39 999 are *parameterized replaceable events*, keyed by the triple (pubkey, kind, d-tag) [17]. A newer event with the same key supersedes the prior one. Relays do not synchronize with each other, so agents must publish to every desired relay independently: relays are substitutable transport, not a trust root. We adopt Nostr because it co-locates BIP340 identity with that substitutable transport.

2.4 L402: Lightning-Gated Authentication

Macaroons [5] are bearer credentials whose scope is constrained by HMAC-chained caveats. The Lightning Network [30] enables trustless micropayments via hash time-locked contracts. L402 [27] combines these primitives by pairing a macaroon with a Lightning invoice. The client pays, obtains the preimage, and presents both as a unified credential. Embedding the agent’s BIP340 public key in the macaroon identifier binds the credential to the requesting agent, an integration detailed in Section 4.6.

3 Related Work

Table 2 compares ten representative systems across seven architectural axes chosen to operationalize the gaps of Section 1, so that the comparison and the evaluation measure the same things: A1 decentralized identity (the sovereignty predicates P1 through P5, Section 4.1), A2 scoped attenuated delegation (G2), A3 key rotation with continuity (G1), A4 peer trust attestation with formal aggregation (G3), A5 identity-bound payment credential (G5), A6 relay-only infrastructure (G4 and deployment footprint), and A7 the STRIDE residual profile as a summary security posture. Evidence superscripts separate measured marks (NostrAgent) from literature-sourced and protocol-analytic ones. Section 5.6 discusses this asymmetry. A6 is a property with a cost: relay-only operation removes registration authorities and consensus infrastructure but gives up the global consistency anchored systems get in return (TP-1 and FM-15, both treated in Section 5). MCP [3] and A2A [1] are excluded as compositional rather than competing: they standardize interaction, not identity (Section 2.1).

Vaidhyanathan and Taibi’s review of ten general-purpose agentic frameworks finds a maturing but fragmented landscape with limited memory models, basic reasoning, and uneven ecosystem support, and notes that security remains largely underdeveloped [43]. NostrAgent addresses identity-layer deficits outside that framework-centric scope (G1 through G3), while G4 and G5 address the deployment seams between organizations. Framework-internal gaps such as memory and reasoning are orthogonal to this substrate layer. NostrAgent instantiates the Self-Sovereign Identity layer of the Sovereign-by-Design reference architecture [15] for agent identity.

3.1 Centralized Approaches

OAuth 2.1 [19] remains the standard mechanism for agent authorization. Tokens are issued by an identity provider (IdP), binding agent identity to a centralized authority and violating sovereignty by design: discovery routes through the provider (G4), and key continuity belongs to the provider rather than the operator (G1). The Agent Authorization Profile (AAP) [10] refines OAuth for multi-agent delegation with hop-counting **delegation** claims, but inherits the same IdP dependency, and its JSON Web Token (JWT) credentials do not support offline

attenuation (G2 partial). The Agent Identity Protocol (AIP) [32] offers two modes: `aip:web`: anchors identity to DNS, while `aip:key`: uses self-certifying Ed25519 keys, architecturally equivalent to BIP340 keys. AIP’s Biscuit/Datalog [8] policy engine is more expressive than tag-based scoping (TP-5, Section 5.2), and it ships a 600-test adversarial suite and an IETF draft [32,31]. Even so, `aip:key`: provides no key rotation (G1), relay-based discovery (G4), peer attestation (G3), or payment binding (G5). SAGA [42] provides the strongest centralized governance model, with ProVerif-verified secrecy and authentication properties (A7), but requires a centralized Provider as sole trust root.

3.2 DID-Family Approaches

The W3C DID specification [41] provides a general-purpose decentralized identifier framework, but key management varies by method: `did:web` depends on DNS, while `did:key` is self-certifying yet offers no rotation (G1). Composing delegation and attestation requires layering separate specifications (Verifiable Credentials [40] for attestation, ZCAP-LD [24] for authorization), with no unified delegation chain supporting scope attenuation (G2). Recent DID+VC proposals for agents [34] inherit the rotation gap. UCAN [46] provides attenuated capability delegation as DID-signed bearer envelopes (G2) but lacks identity-layer key rotation (G1), peer attestation (G3), and payment binding (G5). KERI [38] provides the strongest key rotation in the comparison through witness consensus, pre-rotation, and duplicity detection via the Key Event Log (G1), and its companion specification ACDC [39] supports chained delegation with scope attenuation (G2). NostrAgent’s pre-rotation is deliberately simpler than KERI’s, omitting witness networks and trading duplicity-detection strength (FM-15) for relay-only infrastructure, agent-specific event semantics, and payment integration.

3.3 Blockchain and Nostr-Native

Blockchain-anchored approaches put identity and reputation on-chain. ERC-8004 [12] deploys agent identity and reputation registries across EVM chains at per-operation gas cost, with no scoped delegation chains (G2). Layering ERC-8183 [9] agentic-commerce primitives and x402 [33] payments atop such registries approaches G5 but remains multi-layer. Within the Nostr ecosystem, Clawstr [7] and the agentstr SDK [2], both layered over standard event kinds, specify neither scoped delegation chains (G2), peer attestation (G3), nor key rotation (G1). BitSov [23] defines a Bitcoin-native sovereignty stack at the transport and service layer. NostrAgent is complementary at the agent identity and delegation layer, using the same BIP340 and Lightning primitives. Three contemporary proposals extend this landscape: Vaziry et al. [44] pair A2A AgentCards with x402 micropayments anchored on a ledger; Saavedra [35] formalizes delegation grants with optional blockchain anchoring; and Huang et al. [20] combine DIDs, VCs, and ZKP attestation in a zero-trust design. None combines relay-native identity, attenuated delegation, peer attestation, and Lightning-settled payment on one substrate.

Table 2 summarizes: NostrAgent is the only row with full marks on A1 through A6, KERI/ACDC next closest, SAGA leading on A7 via ProVerif.

Table 2: Comparison of agent identity approaches. $\checkmark$ = Full, $\circ$ = Partial, $\times$ = None. Evidence: M measured, L literature, P protocol analysis, A architectural argument.

System	A1	A2	A3	A4	A5	A6	A7
NostrAgent	$\checkmark^{M,P}$	$\checkmark^{M,P}$	$\checkmark^{M,P}$	$\checkmark^{M,P}$	$\checkmark^{M,P}$	$\checkmark^{A,P}$	$\circ^{M,P}$
AIP (key:)	$\checkmark^{P,L}$	$\checkmark^L$	$\times^P$	$\times^P$	$\times^P$	$\checkmark^P$	$\circ^L$
AIP (web:)	$\times^P$	$\checkmark^L$	$\circ^P$	$\times^P$	$\times^P$	$\times^P$	$\circ^L$
KERI/ACDC	$\checkmark^{P,L}$	$\checkmark^{P,L}$	$\checkmark^{P,L}$	$\times^P$	$\times^P$	$\circ^{P,L}$	$\circ^A$
W3C DID (did:web)	$\circ^{P,L}$	$\circ^P$	$\circ^P$	$\circ^P$	$\times^P$	$\circ^P$	$\times^A$
ERC-8004	$\circ^{P,L}$	$\times^P$	$\circ^P$	$\circ^{P,L}$	$\circ^P$	$\times^P$	$\times^A$
Clawstr/agentstr	$\checkmark^P$	$\times^P$	$\times^P$	$\times^P$	$\circ^P$	$\checkmark^P$	$\times^A$
SAGA	$\times^{P,L}$	$\circ^L$	$\circ^L$	$\circ^L$	$\times^P$	$\times^{P,L}$	$\checkmark^L$
AAP (IETF)	$\times^P$	$\circ^L$	$\circ^P$	$\times^P$	$\times^P$	$\times^P$	$\times^L$
OAuth 2.1	$\times^{P,L}$	$\circ^P$	$\circ^P$	$\times^P$	$\times^P$	$\times^P$	$\times^L$

A1 Decentralized identity; A2 Scoped attenuated delegation; A3 Key rotation with continuity;
A4 Peer trust attestation with formal aggregation; A5 Identity-bound payment credential;
A6 Relay-only infrastructure; A7 STRIDE residual profile.

The marks in Table 2 record design trade-offs, not a ranking. Centralized systems (OAuth, AAP, SAGA) buy governance, and in SAGA’s case machine-checked security, at the cost of an identity provider, which is exactly G4 and the operator-sovereignty predicates. KERI/ACDC is strongest on key continuity and attenuated delegation, but requires witness infrastructure that the relay-only choice (A6) forgoes, leaving FM-15 as the residual. AIP’s self-certifying mode matches our key model and exceeds our policy language (TP-5), yet has no rotation, attestation, or payment binding. Blockchain registries buy global consistency that relays cannot, at per-operation cost and without scoped chains. Nostr-native agent work inherits the relay substrate but does not specify G1-G3. NostrAgent’s bet is the opposite of KERI’s: simpler infrastructure, agent-specific event semantics, and identity-bound payment, in exchange for no duplicity detection and no global log. Section 5 measures that cost.

4 NostrAgent Architecture

4.1 Design Principles

The architecture rests on five operator-sovereignty predicates that formalize the operator’s control over agent identity. **P1 (Existence Independence):** an agent’s keypair can be created without interaction with any external service. **P2 (Verification Independence):** any party verifies identity and delegation chains using only the public key and signed events, without contacting a third party. **P3 (Infrastructure Portability):** identity, delegation chains, and attestations migrate to any compatible relay without re-registration. **P4 (Operator Supremacy):** the operator can unilaterally revoke, rotate, or re-scope identity

and delegations. **P5 (Non-Forgery by Infrastructure)**: no relay or Lightning node can forge or modify identity without the private key. These predicates align with the sovereignty conceptualization of Esposito et al. [15]: Controllability relates to P4, Autonomy to P1 and P3, Verifiability to P2 and P5.

Figure 1 shows the component-and-connector view on the running example. The operator, holding the identity secret key, issues a root delegation (Kind 38101) to agent A. A then sub-delegates a narrowed scope to B, and the two agents exchange peer attestations (Kind 38102, dashed) whose accumulation forms the emergent trust graph. Both agents publish their events to a relay set mixing an operator-controlled relay (solid border) with public relays (dashed). Relays store and forward but cannot forge. B pays the service through L402 (double arrow). Three trust boundaries anchor the STRIDE analysis (Section 5.4): TB1 agent-relay, TB2 agent-agent, TB3 agent-service.

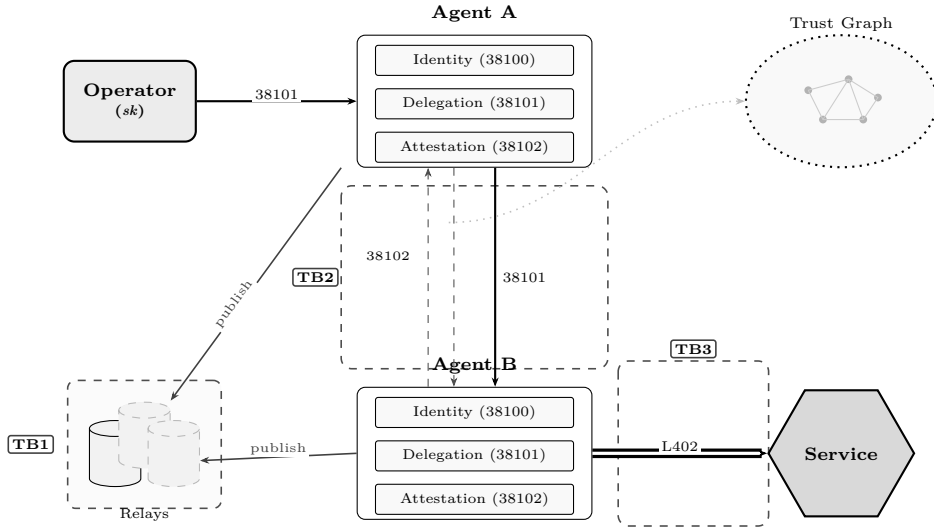


Fig. 1: NostrAgent component-and-connector view with trust boundaries TB1 to TB3. Solid arrows: delegation (Kind 38101); dashed: attestation (Kind 38102); double: L402 payment. Relay borders: solid = operator-controlled, dashed = public.

4.2 Agent Identity (Kind 38100)

Kind 38100 is parameterized replaceable, so each agent identity has a single canonical declaration at any time. The operator-chosen **d**-tag serves as a stable agent identifier (e.g., **weather-agent-v1**), the **p**-tag references the operator's public key, and one or more **t**-tags declare relay-filterable capabilities such as **weather-forecast**. The JSON content carries the agent's name, version, capability list, MCP and A2A endpoint URLs, and trust policy parameters. A **next_key_hash** tag commits the agent to a specific successor key for pre-rotation (Section 4.5). Agents and verifiers discover identities through NIP-01 relay filters selecting by event kind, author public key, **d**-tag, or capability **t**-tag. In the

running example, B finds the data service S by filtering for its capability tag. Operators choose their own relay set, and multi-relay publishing makes discovery a query that no single relay can forge or suppress.

4.3 Delegation Chains (Kind 38101)

A Kind 38101 event encodes a scoped delegation from a delegator to a delegatee. Each event specifies a scope (capabilities, resources, actions), constraints (expiration, maximum chain depth, current depth), and a reference to the parent delegation or identity event via an **a**-tag.

Verification walks the chain from leaf to root, checking seven invariants at each hop: **INV-1 (Capability)** child capabilities $\subseteq$ parent capabilities; **INV-2 (Resource)** child resources $\subseteq$ parent resources (empty set denotes unrestricted); **INV-3 (Action)** child actions $\subseteq$ parent actions (empty set denotes unrestricted); **INV-4 (Depth)** current depth $\leq$ maximum chain depth; **INV-5 (Time)** child expiration $\leq$ parent expiration; **INV-6 (Continuity)** delegatee of hop n equals author of hop $n+1$; **INV-7 (Acyclicity)** no cycles, enforced by a visited-set check. Together these guarantee per-hop narrowing at every link. For capabilities, which must be non-empty at every hop, narrowing is additionally transitive end to end. Attenuation is verifier-enforced rather than cryptographically bound at the signer, trading macaroon-style HMAC chaining for the simpler relay-replaceable model.

The empty-set convention in INV-2 and INV-3 creates an asymmetry. It exists for root-delegation ergonomics: an operator granting initial authority typically constrains capabilities but not yet every resource those capabilities may touch. Exhaustive root resource lists would invite wildcards with the same effect and less clarity. The consequence: because subset checks are per hop, a chain passing through an unrestricted intermediate hop does not preserve earlier resource or action restrictions. Capability narrowing, by contrast, is transitive because empty capability sets are rejected at creation. Section 5.5 discusses when this matters.

Like Kind 38100, Kind 38101 is parameterized replaceable, so cascade revocation works in-band: publishing a replacement with **revocation_status** set to **"revoked"** invalidates that event and all downstream delegations, since any subsequent chain walk encounters the revoked ancestor and halts. Unlike bearer macaroons [5] with external revocation state, Kind 38101 delegations revoke in-band and are non-transferable: INV-6 binds each hop to a specific delegatee public key, so the credential cannot be reused by any other party. Figure 2 traces both halves: the operator delegates $\{a, b, c\}$ at depth 1 of 3 to A; A passes the narrowed $\{a, b\}$ to B; the verifier accepts after walking the invariants. Below, the operator revokes the root by republishing its **d**-tag with revoked status, and the next walk rejects.

4.4 Peer Attestation and Trust (Kind 38102)

To let agents form a transitive trust graph independent of relay or operator authority, Kind 38102 records a signed peer attestation: agent *A* attests that

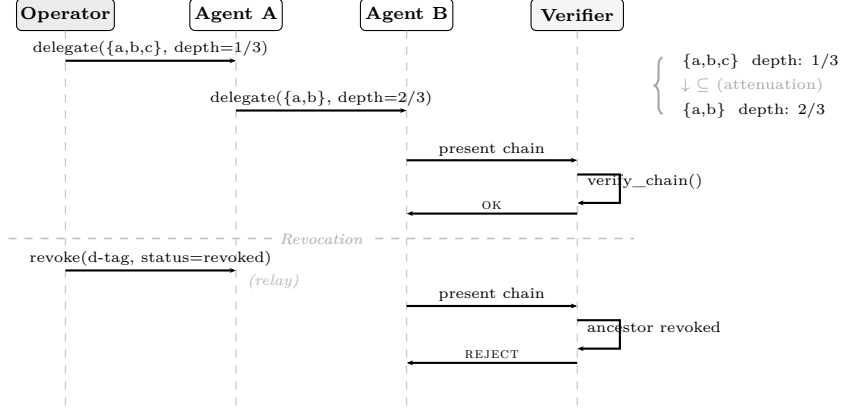


Fig. 2: Delegation chain with scope attenuation (top) and cascade revocation (bottom).

agent B possesses capability C with confidence $w \in [0, 1]$, serving as the edge weight in a directed trust graph. Trust computation uses depth-first search from the querying agent’s operator-configured trust roots (anchors). Each path between A and B contributes independent evidence, combined via a noisy-OR gate [29]: $\text{trust}(A, B) = 1 - \prod_{p \in \mathcal{P}_{A \rightarrow B}} (1 - d^{|p|} \prod_i w_i)$, with $|p|$ the path edge count, defaults $d=0.5$ and $\text{depth} \leq 4$, and paths below $\epsilon=0.01$ pruned. The score is bounded in $[0, 1]$ and monotone in path weights. The cost of the independence assumption is bounded analytically (Section 5.5). L402’s per-identity cost floor makes the scheme Sybil-deterrent through economic friction rather than formally Sybil-resistant [13]. Attestations are strictly positive to prevent weaponized reputation attacks. Like Kinds 38100 and 38101, Kind 38102 is parameterized replaceable, keyed by the deterministic (attester, attestee, capability) d-tag, so attesters update confidence weights or revoke attestations in-band by republishing. This graph is how B chooses among competing weather services: attestations from A ’s anchors outweigh a newcomer’s self-description.

4.5 Key Rotation with Pre-Rotation

Pre-rotation [38] commits to a successor key before it is used, defending against compromise of the active key. At identity creation, `next_key_hash` commits $\text{SHA256}(\text{next_pubkey})$ over the 32-byte x-only encoding. At rotation, the old key publishes status `rotated` and the new key publishes status `active` with a `prev_key` tag and a `rotation_proof`: a BIP340 signature by the new key over $\text{SHA256}(\text{old_pk} \parallel \text{new_pk} \parallel \text{timestamp})$. Verifiers reject any rotation in which $\text{SHA256}(\text{new_pk})$ differs from the prior `next_key_hash`. A grace period (default 3600s) for relay propagation precedes old-key event rejection. This lets O rotate a suspected-compromised key without losing B ’s delegation or A ’s attestations.

4.6 L402 Unified Identity-Payment

The L402 flow proceeds in three phases (Fig. 3). In the *Challenge* phase, an agent presents its BIP340 public key to a service, which responds with HTTP 402

containing a macaroon and a Lightning invoice. The macaroon identifier is a 65-byte structure: version (1 B), payment hash (32 B), and agent public key (32 B), binding the credential to the requesting agent. In the *Payment* phase, the agent pays the invoice via its LND node and obtains the preimage. In the *Access* phase, the agent resubmits the request with the macaroon, preimage, and a BIP340 signature over the canonical request (method, URL, timestamp, and body hash). The service performs five verification checks: preimage validity, identity match, BIP340 signature verification, timestamp freshness, and caveat satisfaction. The macaroon remains a bearer credential, but the preimage proves invoice settlement and the request signature proves key possession at access time. Together they authenticate the agent at verification rather than at issuance [5]. Omitting the signature check degrades the credential to a bearer token, so deploying services must enforce it.

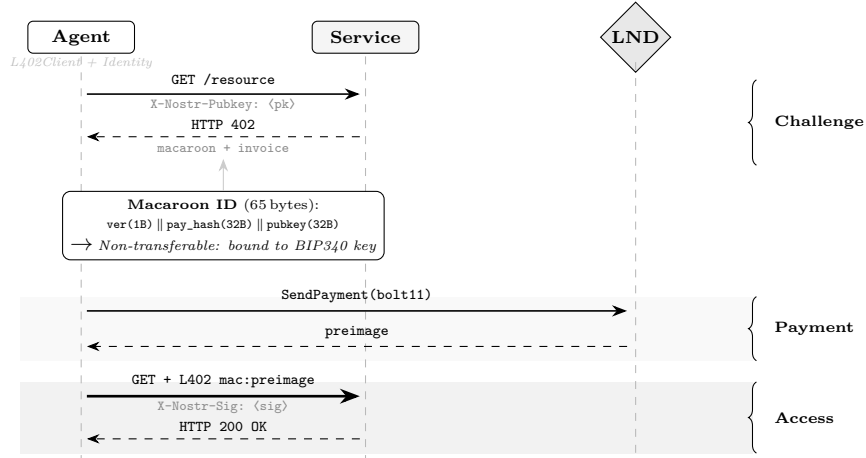


Fig. 3: L402 unified identity-payment flow. The 65-byte macaroon identifier binds the credential to the agent’s BIP340 public key, making it non-transferable.

4.7 Prototype

The prototype is implemented in Python 3.11 with `nostr-sdk` (Rust bindings) for BIP340, `pymacaroons` for L402, and LND on regtest. All three event kinds, key rotation with pre-rotation, and L402 payment verification are fully implemented. The test suite comprises 359 test functions spanning unit, property-based, adversarial STRIDE, and Docker integration layers. The benchmark testbed and environment are described in Section 5.1.

4.8 What the Composition Buys

Verification locality. Every check, from BIP340 signatures through the seven invariants and trust aggregation to L402’s five checks, is a pure computation over signed events plus the payment preimage. Retrieval is separable from checking:

verifiers fetch events from any relay or local cache, then decide offline, contacting no issuing authority. S authorizes B’s request without calling the operator, A, or any authorization server, in well under a millisecond of compute (B3, B11).

Cross-layer key binding. One BIP340 key signs the identity event, sits inside the 65-byte macaroon identifier, and signs each L402 request. Identity, authorization, and payment therefore hold or fail together: a stolen macaroon plus preimage is unreplayable because the third element, key possession, cannot be lifted from the event log (B11).

Priced trust. Free attestation edges and priced identities are individually weak defenses. Composed, they yield measurable Sybil deterrence (FM-8, FM-13). The property lives in neither module: the trust engine has no notion of payment, and L402 has no notion of trust (Section 5.3).

Lifecycle uniformity. With all three kinds parameterized replaceable, rotation, revocation, and retraction are one republish-under-the-same-d-tag operation, so revocation cascades in-band with no revocation service (B8).

Read against the predicates and gaps of Sections 4.1 and 1: P1, P2, and G4 are Kind 38100 plus NIP-01 filters; P4, G1, and G2 are pre-rotation plus the Kind 38101 invariants and in-band replaceability; G3 is Kind 38102 with the L402 cost floor; G5 is the 65-byte macaroon binding. P3 and P5 follow from relays being substitutable and unable to forge BIP340 events. The security and sovereignty properties claimed in Section 1 are these mechanisms in combination, not any one of them.

5 Evaluation and Discussion

This section answers RQ1 through RQ3 with a mixed-method design: ATAM scenario analysis with priorities rated by an expert panel (RQ1), benchmarks organized as a gap-fulfillment analysis (RQ2), and STRIDE enumeration plus adversarial failure-mode testing (RQ3). The methods are complementary: expert judgment establishes which qualities matter and how hard they are, benchmarks quantify the prioritized behaviors, and the security analyses probe the same architecture under attack rather than under load.

5.1 Evaluation Setup

All experiments run against the prototype (Section 4.7) in one of three environments. Offline microbenchmarks measure pure verification computations in-process, with no network; each metric runs 1000 times, the first 100 discarded as warm-up ($N=900$). Docker benchmarks run against a live testbed of six Compose containers: three strfry Nostr relays, two LND Lightning nodes, and one bitcoind node in regtest mode (a private, deterministic Bitcoin network). These run 100 times each, with 10 warm-up discards for the stateful flows B7 to B9 ($N=90$). One failure-mode test (FM-11) publishes to five public Nostr relays over the open internet, the only measurement in this paper taken outside local infrastructure.

Table 3: Benchmark definitions. Offline = in-process cryptographic microbenchmark; Docker = live Compose testbed. Run counts and warm-up protocol in Section 5.1; results in Table 4.

ID	What it measures	Env.
B1	Kind 38100 verification: serialization, event-id recomputation, BIP340 verify, content parse	Offline
B2	Isolated BIP340 signature verification, per event kind	Offline
B3	Delegation-chain verification at depths 1 through 4	Offline
B4	Relay discovery of a Kind 38100 identity across 1 to 3 relays	Docker
B5	Kind 38102 attestation validation: schema, event id, signature	Offline
B6	Trust-graph query (noisy-OR depth-first search), 5 to 500 nodes	Offline
B6b	Trust-query variant of B6: depth-limit and decay sweeps	Offline
B7	End-to-end key rotation published through the relays	Docker
B8	Revocation propagation until all three relays serve the revoked event	Docker
B9	Full L402 flow: challenge, Lightning payment, five-check verification	Docker
B10	Macaroon attenuation cost at 1 to 20 caveats	Offline
B11	Five-check L402 credential verification in isolation	Offline

Table 3 defines B1 to B11 and their environments; B6b is a parameter-sweep variant of B6. The trust-graph benchmarks build seeded Erdős-Rényi [14] synthetic graphs (edge probability 0.15).

Comparisons between NostrAgent configurations use two-sided Mann-Whitney U tests with Cliff’s delta effect sizes [4]. Every pairwise sweep comparison (chain depth B3, relay count B4, graph size B6, depth limit B6b, caveat count B10) is significant at $p < 0.001$ with a large effect ($|\delta| \geq 0.94$); per-pair results and exact dependency versions are in the replication package. All runs fix seed 42 (Apple Silicon macOS host, Python 3.11).

5.2 RQ1: Architectural Trade-offs

RQ1 asks how NostrAgent’s design choices trade among sovereignty, operability, and trust. Following lightweight ATAM [21,36], informed by the six of AgentArcEval’s eleven agent quality attributes [25] that bear on the identity layer, we selected twelve quality-attribute leaves and organized them into a three-branch utility tree (Table 5). Three independent anonymous experts in relevant fields rated each leaf on importance and difficulty in a two-round mini-Delphi [11]: a blind asynchronous rating round, then a synchronous convergence session. Round 2 agreement was near-perfect: Krippendorff’s $\alpha = 0.94$ [22] averaged across axes (importance 1.00, difficulty 0.88; 95% bootstrap CI [0.78, 1.00]), up from 0.79 in Round 1. Fleiss $\kappa = 0.78$ [18] on joint (importance, difficulty) categories for ATAM comparability, up from 0.46 in Round 1. The panel reached unanimity on nine of the twelve leaves and left three persistent difficulty dissents (O2, T1, T4), flagged in Table 5.

Table 4: NostrAgent benchmark results: representative medians per benchmark B1 to B11, with the full B3 depth and B6b $D_{\max}$ sweeps. B6 holds $D_{\max}=4$ (default); B6b sweeps $D_{\max}$ at fixed $n=50$. Environments per benchmark in Table 3.

ID	Variant	Median (ms)	IQR	P95	P99	N
B1	kind_38100 auth	0.0165	0.0005	0.0169	0.0204	900
B2	BIP340 verify (all kinds)	0.0154	0.0001	0.0157	0.0169	900
B3	depth 1	0.0155	0.0001	0.0159	0.0196	900
B3	depth 2	0.0308	0.0005	0.0320	0.0365	900
B3	depth 3	0.0460	0.0001	0.0487	0.0520	900
B3	depth 4 (≈ 15 us/hop)	0.0619	0.0002	0.0658	0.0698	900
B4	discovery, 3 relays	2.3	0.20	2.7	2.8	100
B5	kind_38102 attestation	0.0168	0.0001	0.0174	0.0226	900
B6	trust query, 5 nodes	0.0005	0.0000	0.0005	0.0015	900
B6	trust query, 100 nodes	3.0	0.07	3.2	3.6	900
B6	trust query, 500 nodes	2422.4	175.3	2918.3	3275.9	900
B6b	$D_{\max}=2$ ($n=50$)	0.0100	0.0003	0.0104	0.0107	900
B6b	$D_{\max}=3$ ($n=50$)	0.0659	0.0008	0.0688	0.0748	900
B6b	$D_{\max}=4$ ($n=50$)	0.4487	0.0041	0.4602	0.4704	900
B7	key rotation	235.8	7.9	277.6	289.8	90
B8	revocation propagation	336.8	9.4	352.6	392.4	90
B9	L402 full flow	157.4	9.6	166.7	170.1	90
B10	macaroon, 10 caveats	0.0517	0.0005	0.0545	0.0598	900
B11	L402 5-check verification	0.0552	0.0004	0.0577	0.0633	900

Table 5: ATAM utility tree with final Round 2 (importance, difficulty) ratings from the mini-Delphi panel; the bold **H,H** leaves are the differentiators anchoring RQ1.

Branch	Leaf Concern	(Imp, Diff)
Sovereignty	S1 Offline verifiability	H,H
	S2 Censorship resistance (relay migration)	H,M
	S3 Key portability (rotation enforcement)	H,H
	S4 Infrastructure independence	M,L
Operability	O1 Verification latency	H,M
	O2 Framework interoperability ^d	M,M
	O3 Auditability (chain reconstruction)	H,M
	O4 Modifiability (schema extension)	M,L
Trust	T1 Attestation validity (forgery rejection) ^d	H,L
	T2 Trust graph integrity after rotation	H,H
	T3 Sybil deterrence (ring bounding)	H,H
	T4 Trust bootstrapping (cold start) ^d	M,M

^done persistent difficulty dissent (Sect. 5.2).

A sensitivity point (SP) is a parameter whose variation measurably shifts a leaf’s response, each mapped to a backing benchmark or failure-mode test. A trade-off point (TP) is a decision in which improving one leaf demonstrably harms another. Four H,H leaves are the differentiators, each with a measured anchor: S1 offline verifiability (depth-4 chain verifies in 0.062 ms, B3), S3 key portability

(rotation 236 ms, B7, old-key events rejected in all trials), T2 trust-graph integrity (attestations survive rotation), and T3 Sybil ring bounding (up to about 20,000 sats per fabricated trust unit, FM-13).

TP-1 (relay federation: availability vs. consistency). Multi-relay publishing buys censorship resistance (S2) and offline verifiability (S1) at the price of consistency: relays never synchronize, so verifiers can observe divergent event sets. B4 prices the added latency; FM-14 and FM-15 characterize the consistency cost.

TP-2 (auditability vs. relationship privacy). Kind 38102 publishes the attestation graph in cleartext: exactly what makes chains reconstructible (O3) and trust replayable, and what concedes relationship metadata to any observer. The cost holds by construction rather than by measurement, and Table 8 rates it the dominant Information Disclosure residual.

TP-3 (single-level pre-rotation vs. propagation window). Pre-rotation hardens S3 but opens a grace window (default 3600 s) while relays propagate. Measured via B7 and B8, probed by FM-6 and FM-12.

TP-4 (L402 coupling). Binding identity to Lightning settlement buys the G3 cost floor (FM-13) but couples the architecture to Lightning liveness. Measured via B9 (the round-trip cost), probed by FM-4 (clean recovery from an LND outage).

TP-5 (tag-based scoping vs. expressiveness). Tag scopes verify in microseconds offline with a small auditable verifier but cannot express temporal or relational constraints. AIP’s Biscuit/Datalog engine is strictly more expressive. The empty-set convention that makes root delegations ergonomic also limits attenuation transitivity for resources and actions (Section 4.3), a disclosed cost of simplicity. Measured via B10 and B11.

Sensitivity points (SP-1 to SP-5, Table 4). Each SP is a deployment knob, and the sweeps justify the defaults Section 4 ships. Relay count moves resolution from 1.4 to 2.3 ms across one to three relays (SP-1, B4), so S2’s relay migration is bounded by republishing (B7, B8) rather than discovery. Chain depth (O1) scales linearly at roughly 15 microseconds per hop (SP-2, B3). The depth limit $D_{\max}$ is the dominant cost knob, a $45\times$ spread across $D \in \{2, 3, 4\}$ at $n=50$ (SP-3, B6b). The default 4 buys the widest attestation-path coverage for 0.45 ms, and because depth also extends Sybil-ring reach it is the first lever to lower under load. Pre-rotation (S3) rejects every competing rotation tested (SP-4, FM-6). Query cost plateaus at decay $d \geq 0.5$ (SP-5, B6b), where the $\epsilon=0.01$ prune stops truncating depth-4 paths, placing the default $d=0.5$ at the knee.

5.3 RQ2: Does Unification Close the Gaps?

RQ2 asks whether unifying identity, trust, and payment on one substrate yields architectural advantages over composing separate systems. We answer against the five gaps of Section 1: Table 6 maps each gap to its mechanism and evidence, and the text walks the two gaps where unification does the most work.

Table 6: Gap fulfillment: the five deficits of Section 1, the mechanism closing each, and the measured evidence.

Gap	Mechanism	Evidence
G1 key continuity	Pre-rotation and chain (Sect. 4.5)	B7: rotation 236 ms; FM-6: competing rotations rejected; FM-7: continuity; attestations survive rotation (T2)
G2 attenuated delegation	Kind 38101, INV-1 through INV-7 (Sect. 4.3)	B3: linear verification at roughly 15 μ s per hop; B10: 4.2 μ s per caveat; B8: revocation on all relays in 337 ms; FM-9 and FM-17: escalation rejected
G3 peer trust	Kind 38102 attestations, noisy-OR aggregation, L402 cost floor (Sect. 4.4)	FM-8: decay caps Sybil trust at 0.714 vs. 1.0; FM-13: 10,000 to 20,000 sats per unit of fabricated trust; B6: query scaling
G4 registry-free discovery	Kind 38100, NIP-01 multi-relay publishing (Sect. 4.2)	fil-B4: resolution 1.4 to 2.3 ms (SP-1); FM-1: graceful degradation; FM-2: omission defeated
G5 identity-bound payment	65-byte macaroon identifier, bound preimage, BIP340 request signature (Sect. 4.6)	B9: settlement 157 ms; B11: five checks in 0.055 ms; FM-4: LND-outage recovery

G5: identity-bound payment. The L402 flow of Section 4.6 collapses identity verification and payment settlement into one HTTP exchange (Fig. 3). B9 reports 157 ms median end to end on regtest, dominated by the Lightning round-trip. B11 isolates the five-check verification at 0.055 ms. The preimage and identity checks bind only public values, so the BIP340 request signature is the sole proof of key possession.

G3: priced peer trust. Deterrence emerges from composing two individually weak mechanisms. Noisy-OR with decay caps what a ring of fake identities extracts: FM-8 bounds honest-to-Sybil trust at 0.714 versus 1.0 (28.6% reduction at $d=0.5$, three bridges). Yet without a cost floor a 20-node ring still saturates its trust mass at 0.998 (FM-13). The 1000-sat-per-identity L402 floor prices that ring, raising fabrication cost from about 10,000 sats per trust unit at five identities to about 20,000 at saturation. The scheme is Sybil-deterrent through economic friction, not formally Sybil-resistant: identity cost is linear with no superlinear penalty, and clearing a decision threshold is far cheaper than saturating trust, since five identities already reach 0.48 for 5,000 sats.

G1, G2, and G4 close on the same substrate with the evidence listed in Table 6. The notable single number is B8, where an in-band revocation becomes visible on all three relays in 337 ms median. Trust-query cost (B6, Table 4) grows steeply with graph size. The controlling knob is $D_{\max}$ (SP-3), and Section 5.5 turns the measured curve into deployment guidance. The answer to RQ2 is architectural: one key and one event log yield properties a composed stack cannot express,

identity-bound payment (G5) and in-band cascade revocation (G2), with the head-to-head latency comparison left unmeasured (Section 5.6).

5.4 RQ3: Failure Modes and Threat Analysis

RQ3 asks what failure modes arise in an operator-sovereign, relay-based architecture. The catalog enumerates 19 modes spanning relay availability, key management, trust-graph manipulation, Lightning unavailability, cross-relay consistency, and cryptographic correctness. 17 are empirical (11 offline cryptographic, 5 on the Docker testbed, and FM-11 against public relays) and all pass. FM-3 is an analytical redundancy bound, and FM-15 is an acknowledged architectural limitation (Section 5.5). Table 7 lists per-mode results. FM-3 bounds unrecoverable data loss at $(1 - p)^R$ for R independent relays ($\leq 10^{-6}$ at $R=3$, $p=0.99$), with FM-1 and FM-14 as empirical anchors.

Table 8 reports STRIDE residual risk across TB1 (Agent-Relay), TB2 (Agent-Agent), and TB3 (Agent-Service). BIP340 holds Spoofing and Tampering at 1 or 2 everywhere. Repudiation at TB1 stays a 3 because relays can deny receipt without counter-proof. The dominant residual is Information Disclosure (4 of 5 on TB1 and TB2): observers can reconstruct the attestation graph, intrinsic to the relay-only model (TP-2) rather than a mitigation gap.

5.5 Discussion

Architectural limitation (FM-15). NostrAgent assumes an honest majority in the operator-controlled relay set. Byzantine equivocation across disjoint relay subsets is undetectable without witness consensus (cf. KERI [38]), which the relay-only principle forbids. Relay selection, superset verifier queries with NIP-01 tiebreaking, and pre-rotation bound the blast radius. Relay-only operation is likewise a poor fit where mandatory global consistency or regulated settlement applies.

Operator key compromise. Pre-rotation makes a stolen key recoverable rather than terminal: the attacker holds the active key but not the committed successor, so only the operator can rotate the identity (FM-6). Rotation orphans the delegations issued under the old key, which must be re-issued under the new one (FM-12). The compromised key stops verifying once the grace window closes, but inside that window its signatures still verify and conflicting publications to disjoint relay sets stay undetectable (FM-15).

Attenuation transitivity. An unrestricted intermediate hop does not preserve earlier resource or action restrictions, so end-to-end narrowing holds only for capabilities (Section 4.3). The property-based suite pins the boundary, and FM-17 confirms that escalation against restricted parents is rejected. Deployments needing end-to-end resource narrowing should restrict every hop. Richer policy engines (TP-5) remove the sharp edge.

Production-scale guidance. At fixed edge probability the local scaling exponent rises with graph size, from about 1.7 (5 to 10 nodes) to about 4.5 (200 to 500), because expected degree grows with n . Interpolating the measured

Table 7: Failure mode results (FM-1 to FM-19). FM-3, FM-15 are analytical; the other 17 are empirical and pass. Related modes share a row.

ID	Status	Detail
FM-1	PASS	Relay partition: resolution succeeds with 1/2/3 relays (3.9/3.3/11.1 ms)
FM-2	PASS	Relay malice: union queries defeat censorship-by-omission; BIP340 signatures preclude tampering
FM-4	PASS	L402 fails cleanly on LND outage; recovers without channel corruption
FM-5	PASS	Revocation verification: 33.4 μ s
FM-6	PASS	Key compromise: attacker rejected, legitimate rotation accepted
FM-7	PASS	Key loss: identity chain valid after pre-rotation recovery
FM-8	PASS	Trust poisoning: Sybil trust 0.714 vs honest 1.0 (28.6% reduction, $d=0.5$, 3 bridges)
FM-9, 17	PASS	Chain verification linear to depth 16 (FM-9); escalation rejected, valid narrowing accepted (FM-17)
FM-10	PASS	Temporal validity: ± 60 s tolerance enforced; 30/60 s skew accepted, 120/300 s skew rejected
FM-11, 16	PASS	3 of 5 public relays accepted all three kinds; the other 2 were unreachable, with no kind-based rejection observed (FM-11); 200-event flood publishes at 0.95 ms median (FM-16)
FM-12	PASS	Rotation: old-key orphan delegations invalidated; new-key re-issuance verifies
FM-13	PASS	Sybil cost: linear per-identity, sub-linear marginal cost-per-trust-unit (5/10/20 identities)
FM-14	PASS	Cross-relay consistency: no gossip; agents must multi-relay publish
FM-3, 15	ANALYTICAL	Multi-relay redundancy argument (FM-3); duplicity gap (FM-15)
FM-18, 19	PASS	Offline sanity: 1000 unique keypairs with 0 collisions (FM-18); BIP340 signature validity (FM-19)

Table 8: STRIDE residual-risk across TB1 (Agent-Relay), TB2 (Agent-Agent), TB3 (Agent-Service); 1 (negligible) to 5 (critical) post-mitigation.

Category	TB1	TB2	TB3
Spoofing	2	2	2
Tampering	2	1	2
Repudiation	3	2	2
Information Disclosure	4	4	3
Denial of Service	3	2	3
Elevation of Privilege	2	2	2

segments at $D_{\max}=4$: under 10 ms to roughly 140 nodes, under 100 ms to roughly 250, one second near 410. The depth lever comes first (dropping $D_{\max}$ from 4 to 3 cut latency $6.8\times$ at $n=50$, B6b), then caching and precomputation. Sparser graphs shift the crossings outward, and the guidance is prototype-derived, not production-validated.

Regulatory alignment. Traceable delegation chains and attestations provide transparency artefacts aligned with the OWASP Agentic Top 10 [28], EU AI Act high-risk requirements [16], and the emerging profiles of the NIST National Cybersecurity Center of Excellence [6] and IETF WIMSE [26].

Concessions and assumptions. TP-2 concedes relationship-metadata privacy for auditability (future work: pseudonymous attester keys, attestation-only relays); TP-5 concedes policy expressiveness for sub-millisecond offline verification. We assume secure operator key custody, one honest reachable relay, a classical adversary, and correct nostr-sdk and libsecp256k1 implementations. Side-channel and supply-chain attacks are out of scope. Single-level pre-rotation leaves simultaneous compromise of active and successor keys irrecoverable. Noisy-OR treats trust paths as independent, so when paths share a sub-path the shared support is counted once per path, an always-upward bias that is analytically bounded (any two-hop pair sharing one hop is overestimated by at most $1/16$). The empirical bias distribution is unmeasured and left to future work.

5.6 Threats to Validity

Internal. STRIDE residuals and comparison marks (Tables 8, 2) are author-assigned and carry researcher-bias risk.

External. The testbed uses 5 agents, 3 relays, regtest Lightning, and graphs capped at 500 nodes. Production-scale clustering and mainnet fee dynamics are unobserved. Regtest excludes real network propagation and routing fees.

Construct. The utility tree, STRIDE categories, and axes A1-A7 are author-curated. AgentArcEval and the standard STRIDE taxonomy ground the candidate pool, but leaf selection is author judgment; the experts rated the tree as given, so their agreement covers the ratings, not the tree’s construction. NostrAgent marks are measured while baseline marks are literature-sourced or protocol-analytic, an asymmetry Table 2 makes explicit through evidence superscripts. Likewise, RQ2’s advantage over a composed multi-system baseline is argued analytically and positioned through that comparison. No composed baseline was measured head to head.

6 Conclusion

We have shown that operator-sovereign agent identity, scoped delegation, peer-attested trust, registry-free discovery, and Lightning-gated payment can be unified on a relay-only substrate without a registration authority. NostrAgent closes the five gaps named in Section 1: key rotation preserves identity, delegations, and trust (G1, 236 ms median); every hop verifiably narrows the granted capabilities

and revocation cascades in one event (G2); peer attestation over a priced identity floor deters Sybil fabrication (G3, up to about 20,000 sats per fabricated trust unit); discovery needs no registry (G4, 1.4 to 2.3 ms); and payment credentials bind to the paying agent, so a stolen macaroon is unplayable (G5, settlement at 157 ms on regtest). The contribution is the composition: each primitive is mature in isolation, but one key type, one event log, and one revocation primitive yield offline verification of the whole authorization tuple, in-band cascade revocation, and identity-bound payment in one Lightning round-trip. The result runs on commodity relays and is safe in the tested sense of the catalog: 17 of 19 failure modes pass adversarial tests, FM-3 is bounded analytically, and FM-15 remains the honest limit of the relay-only model. The mixed-method evaluation substantiates C1 through C3, and the replication package delivers C4. Trust-query latency beyond 500 nodes and single-level pre-rotation’s Byzantine-equivocation gap remain the visible limitations. Future work: mainnet L402 validation, large-scale trust simulation with empirical noisy-OR bias measurement and a sweep of the ϵ pruning threshold, formal verification of the attenuation invariants, and NIP standardization of Kinds 38100 through 38102.

Data Availability

The replication package (implementation, benchmark harness, raw results, Docker testbed, tests, ATAM/mini-Delphi materials, failure-mode results) is archived at <https://doi.org/10.5281/zenodo.22744262> and mirrored at <https://github.com/Oliver1703dk/agentics2026-replication-package>. Experiments use fixed seed 42 and pinned dependencies.

References

1. A2A Project: Agent2Agent (A2A) protocol specification. Linux Foundation, <https://a2a-protocol.org/latest/specification/> (2025)
2. Agentstr: Agentstr-SDK: A Python SDK for Nostr-native agents. Open-source software, <https://github.com/agentstr/agentstr-sdk>, accessed July 2026 (2025)
3. Anthropic: Introducing the Model Context Protocol. Anthropic announcement, <https://www.anthropic.com/news/model-context-protocol> (2024)
4. Arcuri, A., Briand, L.: A practical guide for using statistical tests to assess randomized algorithms in software engineering. In: Proceedings of the 33rd International Conference on Software Engineering (ICSE). pp. 1–10. ACM (2011)
5. Birgisson, A., Politz, J.G., Erlingsson, Ú., Taly, A., Vrabie, M., Lentzner, M.: Macaroons: Cookies with contextual caveats for decentralized authorization in the cloud. In: Proceedings of the Network and Distributed System Security Symposium (NDSS). Internet Society (2014)
6. Booth, H., Fisher, W., Galluzzo, R., Roberts, J.: Accelerating the adoption of software and artificial intelligence agent identity and authorization. Concept paper, NIST NCCoE (Feb 2026)
7. Clawstr: Clawstr: A Nostr social network for AI agents. Open-source project, <https://github.com/clawstr/clawstr>, accessed July 2026 (2026)

8. Coupric, G., Delafargue, C.: Biscuit authentication token v3. Eclipse Biscuit Specification (2023)
9. Crapis, D., Lim, B., Weixiong, T., Zuhwa, C.: ERC-8183: Agentic commerce. Ethereum Improvement Proposal, ERC-8183 (Standards Track, Draft) (2026)
10. Cruz, A.: Agent authorization profile (AAP) for OAuth 2.0. Internet-Draft draft-aap-oauth-profile-01, Internet Engineering Task Force (Feb 2026)
11. Dalkey, N., Helmer, O.: An experimental application of the Delphi method to the use of experts. *Management Science* **9**(3), 458–467 (1963)
12. De Rossi, M., Crapis, D., Ellis, J., Reppel, E.: ERC-8004: Trustless agents. Ethereum Improvement Proposal, ERC-8004 (Standards Track, Draft) (2025)
13. Douceur, J.R.: The Sybil attack. In: *Peer-to-Peer Systems (IPTPS 2002)*. LNCS, vol. 2429, pp. 251–260. Springer (2002)
14. Erdős, P., Rényi, A.: On random graphs I. *Publicationes Mathematicae Debrecen* **6**, 290–297 (1959)
15. Esposito, M., Marchesi, L., Tonelli, R., Lenarduzzi, V.: Sovereign-by-design: A reference architecture for AI and blockchain enabled systems (2026), arXiv:2602.05486
16. European Parliament and Council: Regulation (EU) 2024/1689 of the European Parliament and of the Council of 13 June 2024 laying down harmonised rules on artificial intelligence (artificial intelligence act). *Official Journal of the European Union*, OJ L, 2024/1689, 12 July 2024 (2024)
17. fiatjaf and contributors: NIP-01: Basic protocol flow description. *Nostr Implementation Possibilities*, NIP-01 (2020)
18. Fleiss, J.L.: Measuring nominal scale agreement among many raters. *Psychological Bulletin* **76**(5), 378–382 (1971)
19. Hardt, D., Parecki, A., Lodderstedt, T.: The OAuth 2.1 authorization framework. IETF Internet-Draft draft-ietf-oauth-v2-1-15 (2026)
20. Huang, K., Narajala, V.S., Yeoh, J., Ross, J., Raskar, R., Harkati, Y., Huang, J., Habler, I., Hughes, C.: A novel zero-trust identity framework for agentic AI: Decentralized authentication and fine-grained access control (2025), arXiv:2505.19301
21. Kazman, R., Klein, M., Clements, P.: ATAM: Method for architecture evaluation. Technical Report CMU/SEI-2000-TR-004, ESC-TR-2000-004, Software Engineering Institute, Carnegie Mellon University (Aug 2000)
22. Krippendorff, K.: *Content Analysis: An Introduction to Its Methodology*. Sage Publications, 2nd edn. (2004)
23. Larsen, O.A., Larsen, R.T., Moghaddam, M.T.: BitSov: A composable Bitcoin-native architecture for sovereign internet infrastructure. In: *ICSA-C 2026: BlockArch Workshop*. IEEE (2026), to appear. Preprint: arXiv:2603.28727
24. Lemmer-Webber, C., Sporny, M.: Authorization capabilities v0.4.0-draft. W3C Credentials Community Group Editor’s Draft, <https://w3c-ccg.github.io/zcap-spec/>, accessed July 2026 (2026)
25. Lu, Q., Zhao, D., Liu, Y., Zhang, H., Zhu, L., Xu, X., Shi, A., Tan, T., Kazman, R.: AgentArcEval: An architecture evaluation method for foundation model based agents. *Journal of Systems and Software* **232**, 112656 (2026)
26. Ni, Y., Liu, P.C.: WIMSE applicability for AI agents. Internet-Draft draft-ni-wimse-ai-agent-identity-02, Internet Engineering Task Force (Feb 2026)
27. Osuntokun, O.: L402: Authentication and payments for the lightning-native web. Lightning Labs (2020), originally introduced as LSAT; renamed L402 in 2023
28. OWASP Gen AI Security Project: OWASP top 10 for agentic applications 2026. OWASP Foundation, Gen AI Security Project (2026)
29. Pearl, J.: *Probabilistic Reasoning in Intelligent Systems: Networks of Plausible Inference*. Morgan Kaufmann, San Mateo, CA (1988)

30. Poon, J., Dryja, T.: The Bitcoin Lightning Network: Scalable off-chain instant payments. White paper (2016)
31. Prakash, S.: Agent identity protocol (AIP): Verifiable delegation for AI agent systems. Internet-Draft draft-prakash-aip-00, Internet Engineering Task Force (Mar 2026)
32. Prakash, S.: AIP: Agent identity protocol for verifiable delegation across MCP and A2A (2026), arXiv:2603.24775
33. Reppel, E., Caspers, R., Leffew, K., Organ, D., Kim, D., Dalal, N.: x402: An open standard for internet-native payments. Coinbase Developer Platform whitepaper (2025)
34. Rodriguez Garzon, S., Vaziry, A., Kuzu, E.M., Gehrmann, D.E., Varkan, B., Gaballa, A., Küpper, A.: AI agents with decentralized identifiers and verifiable credentials. In: Proceedings of the 18th International Conference on Agents and Artificial Intelligence (ICAART). vol. 1, pp. 252–259. SciTePress (2026)
35. Saavedra, D.R.: Interoperable architecture for digital identity delegation for AI agents with blockchain integration (2026), arXiv:2601.14982
36. Sahlabadi, M., Muniyandi, R.C., Shukur, Z., Qamar, F.: Lightweight software architecture evaluation for industry: A comprehensive review. *Sensors* **22**(3), 1252 (2022)
37. Shostack, A.: Threat Modeling: Designing for Security. Wiley (2014)
38. Smith, S.M.: Key event receipt infrastructure (KERI) (2019), arXiv:1907.02143
39. Smith, S.M.: Authentic chained data containers (ACDC). Internet-Draft draft-smith-acdc-03, Internet Engineering Task Force (Jul 2023)
40. Sporny, M., Den Hartog, K.: Verifiable credentials data model v1.1. W3C Recommendation (2022)
41. Sporny, M., Guy, A., Sabadello, M., Reed, D.: Decentralized identifiers (DIDs) v1.0. W3C Recommendation (2022)
42. Syros, G., Suri, A., Ginesin, J., Nita-Rotaru, C., Oprea, A.: SAGA: A security architecture for governing AI agentic systems. In: Proceedings of the Network and Distributed System Security Symposium (NDSS). Internet Society (2026), preprint: arXiv:2504.21034
43. Vaidhyanathan, K., Taibi, D.: Agentic AI frameworks under the microscope: What works, what doesn't. *IEEE Software* **43**(1), 133–138 (2026)
44. Vaziry, A., Rodriguez Garzon, S., Küpper, A.: Towards multi-agent economies: Enhancing the A2A protocol with ledger-anchored identities and x402 micropayments for AI agents (2025), arXiv:2507.19550
45. Wuille, P., Nick, J., Ruffing, T.: BIP 340: Schnorr signatures for secp256k1. Bitcoin Improvement Proposal 340 (2020)
46. Zelenka, B., et al.: UCAN delegation specification v1.0.0. UCAN Working Group specification, <https://github.com/ucan-wg/delegation> (2025)